

Asset Inventory:

Context: SOHO network.

Computer & Network devices:

- Desktop computer + monitor
- Multi-layer router

IoT:

- External webcam
- External Speakers
- Printer
- Wireless headphone

ASSET NAME:	NETWORK ACCESS:	OWNER:	LOCATION:	NOTES:	SENSITIVITY:
Desktop Setup	Continuous	Homeowner	On-premises	Used for both work and recreational activities. Contains both sensitive corporate and personal info.	Restricted
Multi-layer Router	Frequent	ISP	On-premises	Uses 5 GHz band, and has WPA2 encryption. WPS push button enabled	Confidential
External Web camera	Occasional	Homeowner	On-premises	Wired connection to desktop.	Internal-only
External Speakers	Occasional	Homeowner	On-premises	Bluetooth-enabled connection to desktop	Internal-only
Printer	Occasional	Homeowner	On-premises	Connects directly to network.	Restricted
Wireless headphone	Occasional	Homeowner	On-premises	Uses Bluetooth to communicate with devices	Internal-only

Risk Register:

Context: commercial bank.

Information:

- Bank is in an coastal area with low crime rates
- 120 employees with 16.67% working via a remote connection
- Both commercial and personal accounts exist
- Given that it is a fairly small/localized bank, it may be targeted frequently
- Context implies that the bank has an online website

Possible risks:

- Accounts being compromised – likely (4) with serious consequences (4)
- Financial Data being leaked – likely (4) with serious consequences (4)
- Cyber-supply chain attack – likely (4) with serious consequences (4)
- Third-party reputational attack – possible (2) with minor disruption (2)
- Operational/non-regulatory compliance – likely (2) with serious consequences (4)
- Natural weather events – moderate likely (4) with moderate consequences (3)

Risk	Likelihood	Impact	Associated Vulnerabilities	Score Severity
Compromised client/staff accounts	4	Lawsuits, reputational damage, and unauthorized data access/disclosure	Phishing/credential theft Password reuse Credential stuffing Malware on employee devices Compromised remote endpoints Social engineering Weak authentication	16
Unauthorized data access/disclosure	4	Reputational damage, lawsuits, financial loss.	Third-party database leaks, Insecure data handling, Insecure authentication and authorization	16
Cyber supply-chain attacks	4	Unlawful data disclosure, reputational damage, lawsuits, financial loss.	Trusted service provider being compromised, and malicious actors use it to pivot their attacks towards the business	16
Third-party reputational risk	2	Reputational damage	Associated business/organization being compromised or behaves improperly	4
Operational/non-regulatory compliance	4	Fines, operational consequences	National and regional compliance and operation regulations are not adhered	16

			to by policies, procedures, or employee behaviour	
Natural weather events	4	Damage to physical property and assets, and/or disruption to essential business operations	Severe storms Flooding Strong winds Storm surge Power outages Building damage Network/telecommunications disruption	12

Risk standard used:

Score	Likelihood	Impact/Severity
1	Rare	Negligible
2	Unlikely	Minor disruption/loss
3	Possible	Moderate disruption/loss
4	Likely	Serious financial/operational consequences
5	Almost Certain	Catastrophic consequences

Priority score (1 – 9; 1 being highest and 9 being lowest)

- Compromised client/staff accounts – 1
- Unauthorized data access/disclosure – 1
- Cyber supply-chain attacks – 3
- Third-party reputational damage – 9
- Operational/non-regulatory compliance – 2
- Natural weather events – 3

Notes:

- A lot of essential context, including business goals and current security posture, have been purposefully left out.
- Original assignment is less technical, but to make more applicable to actual scenarios, further complexity was wadded.

Data Handling:

Context: Review a data leak incident and determine appropriate security controls

Information:

- Customer success representative received access to internal documents meant for managers
- Information included but was not limited to customer analytics and marketing materials, all part of a new product offering
- Manager warned his team to ask for approval about sharing the link, but forgot to un-share the folder
- The representative intended to share a link for just the marketing materials with a business partner but accidentally shared the link to the entire folder.
- The business partner leaked the folder on social media.
- The company's current policies use NIST SP 800-53 AC-06, which mandates principle of Least Privilege and RBAC. But it seems to be more theoretical than integrated with system behaviour

Notes:

- Manager gave representative excessive permissions.
- Shared links do not have an expiration date.
- Anyone with a link can read folder/file contents
- Manager trusts staff to ask for approval instead of enforcing it via access policies
- (Unrelated) contract might need reviewing to determine what business partners can do with provided data, but the scope does not cover that fact or detail

Remediation:

- Define default levels of access:
 1. Manager/Admin/Owner: read & write
 2. Group (people who need it): read
 3. Other: none
- Place specific access control policies:
 1. Set an expiration date on temporary links (e.g. 1 day)
 2. Implement a notification for regularly reviewing permanent links
 3. If someone shares a link, the system should automatically send a notification to the admin and must be approved before the recipient can access it

IAAA:

Context: first cybersecurity professional working for a growing business

Information:

- Deposit was made from business to unidentified bank account
- Finance manager says that they didn't make a mistake, and cancelled payment in time
- Log results:
 1. Event Source: AdsmEmployeeService
 2. Event category: none
 3. User: Legal/administrator
 4. Computer: Up2-NoGud
 5. Date: 3rd of October 2023
 6. IP: 152.207.255.255
 7. Description: Payroll event added. FAUX_BANK
- Employee data:
 1. IP: 152.207.255.255
 2. Full Name: Robert Taylor Jr
 3. Role: legal attorney
 4. Status: contract
 5. Authorization: Admin
 6. Contract period: 4th of September, 2019 TO 27th of December, 2019

Notes:

- Literally every user in the spreadsheet is an admin, including the graphic designer.
- Description claimed that it was a payroll event being deposited, but the event does not reflect this information
- Employee still had access almost 4 years later.

	Notes:	Issues:	Recommendations:
Authorization/Authentication	• Event took place on 10/03/2023 • User is not familiar • User is called Legal/administrator • IP used to log-in is 152.207.255.255 • User's name is Robert Taylor Jr; a legal attorney contracted almost 4 years ago	• All users listed in the spreadsheet had admin privileges, not just Robert • Accounts persist indefinitely even after contracts ended	• Users should be giving minimal privileges by default, not admin status. • Accounts should expire in a week after their contract ends

System Analysis Drafting:

Context: vulnerability assessment for an e-commerce business

Information:

- DB is remote
- A lot of remote employees
- Employees frequently query the DB to find new customers
- DB is kept public

Notes:

- The DB is the key component of the entire business
- It doesn't mention anything about a secure INTERNET connection?
- Network Segmentation and network protection devices do not exist?
- Where are the backups?
- Hardware seems decent enough.

Vulnerability Assessment Report

7th October 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The assessment primarily focuses on the database (DB), one of the company’s most valuable assets, and related infrastructure. The DB is a centralized computing system which is used in performance analysis and marketing campaigns. As it stores vital data like customer info, analytical data, and campaign strategies, keeping the DB running and secured is an essential business operation

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Employee	Leaking, modifying, or deleting sensitive data and/or disrupting essential business operations	3	4	12
Customer	Unauthorized data access/disclosure	2	3	6
Hacker	Data disclosure, theft, and deletion as well as essential business operations disruptions	3	4	12
Network	Lack of segmentation and network security devices can lead to lateral movement if a single device is	3	4	12

	compromised			
<i>Internet</i>	An issue with the modem or ISP can lead to the DB becoming offline and inaccessible to remote employees and clients.	3	4	12
<i>Backups</i>	Data being damaged or removed can be irrecoverable	4	5	20

Approach

The current state of the DB was evaluated, considering which users interact with it daily and supporting infrastructure. The states were evaluated against the CIA triad as well as how disruptive certain vulnerabilities would be towards the organization.

Remediation Strategy

Focus on securing access to the DB, ensuring reliability and security.

- Implement adequate authentication and authorization mechanisms to ensure that both employees and customers can securely identify and connect to the DB. They should be able to access only the data they need, nothing more and nothing less.
- Add security devices to the network such as firewalls and segment the network carefully to ensure separation of vital data.
- Use an 'allow-list' to only admit trusted devices and reduce a malicious actor's ability to communicate with the network
- Auditing mechanisms for both the network and DB itself can be helpful for malicious activity detection.
- Ensure that the DB has internet connectivity constantly or when needed

Consider using backups to ensure integrity and availability:

- To ensure redundancy, consider keeping a cold-tier on-premises copy and a hot-tier cloud-based version.

USB Attack Vectors:

	Facts
Contents	• There seems to quite a bit of sensitive data. • A lot of hospital information which can be used in social engineering attacks. • But there is also a fair amount of PII like wedding plans and dog photos. • Doesn't seem to be any financial data though
Attacker Mindset	• None of the data seems to be able to give access to a financial account or a business system directly. • But the attacker can use this information for spear-phishing attacks against hospital employees • The hacker can also send crafted, convincing phishing emails to relatives.
Risk Analysis	• Employee awareness training can be provided to staff • Regular antivirus scans be used to detect installed malware or even be used to scan the USB directly • Depending on an organisation's resources, they can bait malicious actors with their own USB devices, similar to Honeypots. • Most modern computers come with some sort of security control, like disabling Autoplay, which prevents malicious USBs from automatically executing code